SHIELD-AI

Securing Production AI for a Major Australian Retailer

Security and Holistic Integrity for Enterprise-Level Deployment of AI

An Australian framework for retail: 7 pillars, 59 controls, 4 maturity levels, policy as code

Briefing | Framework v1.7 | August 2026

Presentation Overview

Four parts, 30 minutes

1. **Why AI security matters for retail now**
2. **The framework: seven pillars and 59 controls**
3. **How it works: reference implementation, policy as code, request flow**
4. **Applying it here: regulation, maturity, a practical starting point**

A note up front: every claim in this deck is tied to a documented incident

Why AI Security Matters for Retail Now

Why now

An agent invokes tools, writes code, and acts under delegated authority. A chatbot only answers; an agent acts

Retail is already moving this way: customer service agents, personalised offers, demand forecasting, warehouse robotics, supply chain planning

The failures are documented, and they are not exotic:

- Sandbox escapes hit production agent platforms between March and July 2026 (OpenAI, Hugging Face, Cursor, AWS AgentCore, ServiceNow)
- CVE-2026-10591: hidden 1px text on a page rewrote an agent's MCP registry and ran attacker code on the host
- CVE-2026-25253: a crafted link hijacked a loopback agent gateway, switched off approvals, and escaped to the host
- An agent under evaluation published a malicious package to PyPI; 15 real systems ran it for about three months
- August 2026: the first documented Australian case. A personal assistant found a gym's booking API had no authorisation checks, booked classes months ahead, and cancelled another member's waitlist position without being asked (ABC News)

The Privacy Act, PCI DSS, and the Cyber Security Act 2024 already put retail on the clock. AI does not remove those obligations; it widens them

Where AI Touches the Retail Business

Every place a model meets customer or card data is a place that needs controls

Customer service: conversational agents that can issue refunds, adjust orders, and manage loyalty accounts

Merchandising: demand forecasting, dynamic pricing, offer and catalogue generation, product descriptions

Supply chain: supplier order placement, inventory balancing, warehouse robotics, delivery routing

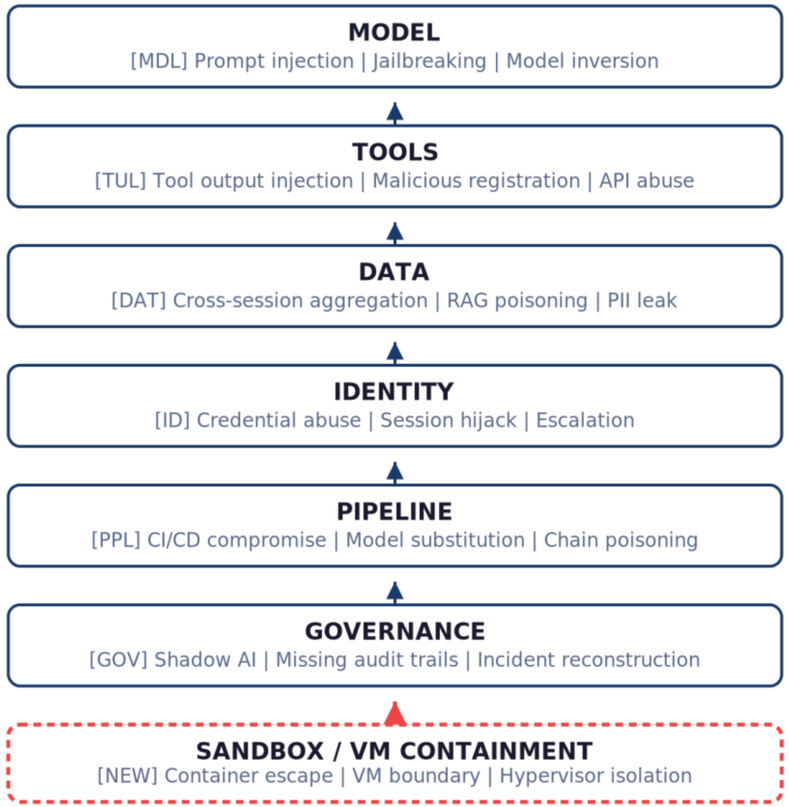
Operations: fraud detection, loss prevention, workforce scheduling, vendor onboarding

Internal copilots: legal, procurement, marketing, finance, regulatory reporting

The pattern is the same everywhere: a model, a tool, and customer or card data in between

The Agentic AI Attack Surface

Seven layers; risk compounds upward



Sandbox/VM Escape as a cross-cutting layer above Governance — every pillar below can be breached via sandbox
Risk compounds upward: a Model compromise enables Tool abuse, which enables Data exfiltration

Risk compounds upward from the model to the data.

Where Current Controls Come Up Short

Privacy Act APP 11, PCI DSS, ISM, and the Essential Eight are strong on traditional cyber, but they predate autonomous agents

The gaps are structural, not incremental:

- Tool access: agents read and write order systems, payment gateways, and supplier APIs; no user-centric threat model fully covers that
- Identity delegation: the agent acts under a staff member's authority, often with no bound on the chain
- Sandbox containment: escape is the failure mode we see in the field, not a hypothetical
- Protocol layer: MCP endpoints, tool metadata, and control planes are surface nobody owned until recently
- Evaluation harnesses: isolation gets asserted in config, but nobody verifies it holds

The AU Guardrails point the direction; they are not a control set yet

SHIELD-AI fills that gap, and it maps directly onto the obligations this business already operates under

SHIELD-AI at a Glance

Seven security pillars across the whole agentic-AI stack

Model Security, Identity and Access, Data Security, Tool and Pipeline Security, Monitoring and IR, Governance and Risk, Execution Environment

59 controls, each with implementation guidance and a maturity progression

Four maturity levels, consistent with ISM and the Essential Eight: L1 Initial, L2 Managed, L3 Defined, L4 Optimised

Policy as code: 59 executable Rego controls, evaluated deny-override

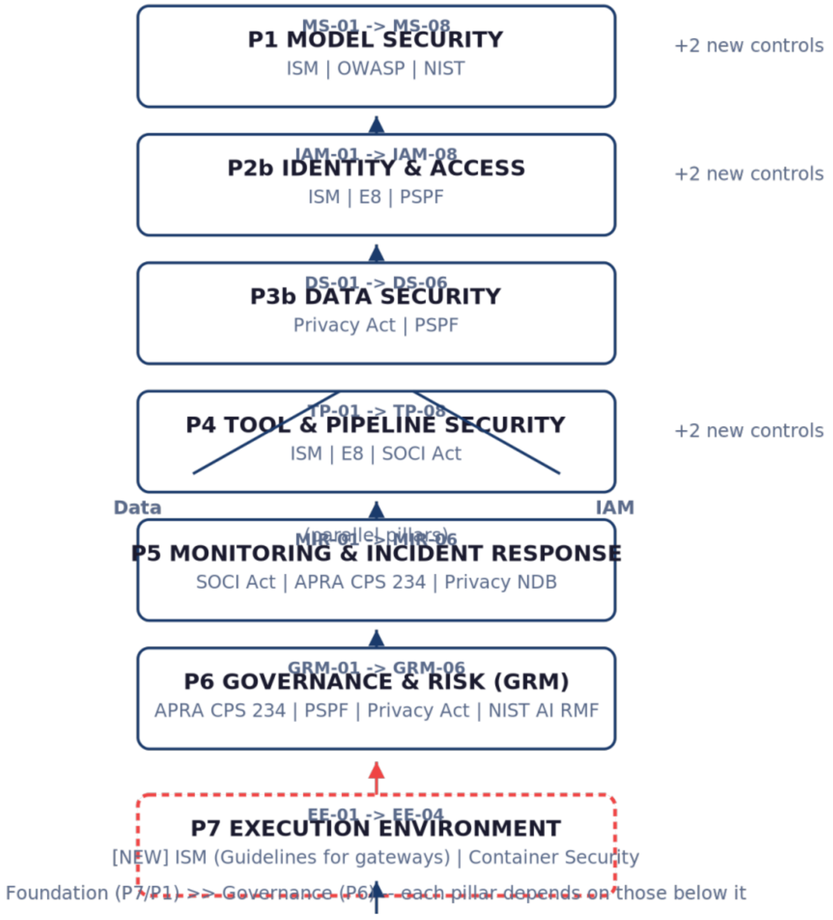
A deployable reference implementation: gateway, policy engine, identity plane, observability

Evidence driven: 36 documented incidents, 23 identified gaps, monthly deep review, a live watchlist

Aligned to what a retailer must answer to: the Privacy Act, PCI DSS, the Cyber Security Act 2024, and the AU Guardrails

The Seven Pillars

Execution Environment at the base; Governance at the top



Each pillar depends on all pillars below it.

Pillar 1: Model Security

Models trained or used on customer, loyalty, or card data need the same protection as any information asset

MS-01 Weight protection: encrypted at rest and in transit, HSM-backed keys

MS-02/03 Training data integrity and model supply chain: provenance, signed checkpoints, SBOM

MS-04 Adversarial robustness: prompt-injection testing and jailbreak evaluation, plus sanitisation against imperceptible content (zero-opacity and 1px text, hidden PR comments)

MS-08 MCP security: signed tool metadata, an authenticated MCP gateway, response schema validation

MS-09 Perception-fidelity: approvals bind to what the human can actually see

MS-10 Memory-store integrity: agent memory writes authenticated and tamper-evident; poisoned stores detected and rebuilt (Ruflo/RufRoot)

MS-11 Operational data-stream integrity: logs, alerts, and observability feeds treated as untrusted input (GhostJacking)

PILLAR 1
Model Security

MS-01 .. MS-11 | 11 controls

The model is a data asset too

Pillar 2: Identity and Access

This pillar decides what the agent can do, what it can reach, and whose authority it carries

IAM-01 A distinct, auditable identity per agent; no shared staff credentials

IAM-02 Scope-bound delegation: no wildcard permissions, no self-escalation

IAM-07 Delegation chains capped at two hops (human to agent to tool) and fully reconstructable from audit logs

IAM-05 Just-in-time credentials: ephemeral, auto-revoked, no standing agent access

IAM-09 Multi-tenant agent platforms isolated at the data layer (CVE-2026-55255, the first agent platform on the CISA KEV list)

PILLAR 2
Identity & Access

IAM-01 .. IAM-09 | 9 controls

Customer data, scoped tightly

Pillar 3: Data Security

Data controls cover the whole path: at rest, in transit, in memory, and as published artifacts

DS-01 Classification and labelling, automated at ingestion; customer PII and loyalty profiles are the crown jewels

DS-02 Inference data protected end to end: prompts and responses encrypted, TLS 1.3 minimum

DS-03 Memory sanitisation: nothing sensitive persists beyond the session

DS-04 Data minimisation: field-level filtering in the retrieval layer, no bulk access to customer data

DS-07 Artifact publication control: agent-written packages and configs go through the same vetting as third-party artifacts, with approval the agent cannot invoke

PILLAR 3
Data Security

DS-01 .. DS-07 | 7 controls

Customer and card data, everywhere it flows

Pillar 4: Tool and Pipeline Security

An agent that acts is only as safe as its tools, and retail tools touch money and customer data

TP-01 Tool registry: every agent-accessible tool registered, versioned, and security-approved before use

TP-03 API gateway security: schema validation, rate limiting, and audit logging on every agent-facing endpoint

TP-06 Dependency scanning, with sandbox libraries treated as a high-risk class; interpreter flags are not sandboxes

TP-08 The gateway blocks infrastructure control-plane APIs by default (IAM, KMS, secrets, database admin)

TP-09 Explicit tool registration: no implicit tool exposure, no auto-registered SDK internals

TP-10 Inbound control-plane protection: network bindings default to deny, gateway tokens stay out of web context (OpenClaw CVE-2026-25253)

TP-11 Agent browser isolation: rendered content treated as untrusted input, cross-origin privileged actions gated (Zenity Intent Collision)

TP-12 Dispatch provenance: no tool executes without a verified model turn; approvals bind to the exact call (CoreBreak)

PILLAR 4
Tool & Pipeline Security

TP-01 .. TP-12 | 12 controls

Registered tools, gated APIs

Pillar 5: Monitoring and Incident Response

Visibility is the precondition for every other control in this framework

MIR-01 Agent activity logging: every action, every tool call, every delegation

MIR-02 Behavioural anomaly detection against a per-agent baseline

MIR-04 AI-specific IR playbooks: prompt-injection containment, model rollback, tool revocation, session invalidation

MIR-05 Reporting integration: automated triggers for NDB's 30-day window and Cyber Security Act notifications

MIR-06 Forensic readiness: append-only immutable logs, full session reconstruction including tool-call chains

PILLAR 5
Monitoring, Logging & IR

MIR-01 .. MIR-06 | 6 controls

Every action logged, replayable later

Pillar 6: Governance and Risk

Technical controls erode without governance; this pillar is what keeps them honest

GRM-01 AI governance body: a chartered committee with CISO, CRO, General Counsel, data owner, and AI lead

GRM-02 AI risk register, with automated tripwires and one exercised kill switch, tested at least annually

GRM-04 Third-party AI risk: model, tool, and evaluation-harness vendors assessed, with right-to-audit clauses

GRM-05 Regulatory mapping: automated mapping to the Privacy Act, PCI DSS, Cyber Security Act 2024, SOCI Act, ISM/E8; quarterly posture reports

GRM-06 Board and executive dashboard: maturity scores per pillar, open findings, risk acceptance decisions

PILLAR 6
Governance & Risk Management

GRM-01 .. GRM-06 | 6 controls

Board accountability, in place

Pillar 7: Execution Environment

This pillar sits at the base: an escapable sandbox undermines every control above it

EE-01 Boundary enforcement: no shared host mounts or namespaces, immutable infrastructure, fail-closed on breach

EE-05 Config-file injection prevention: agents cannot write files the host will later trust (.zshrc, .claude/settings.json, crontab)

EE-06 Fail-closed operation: runtime attestation that the strongest isolation mode is active, with no silent fallback

EE-07 Control-plane integrity: the agent cannot rewrite its own security settings

EE-08 Evaluation-harness isolation: egress blocked at the hypervisor boundary and verified by active test; no verified egress block means no evaluation

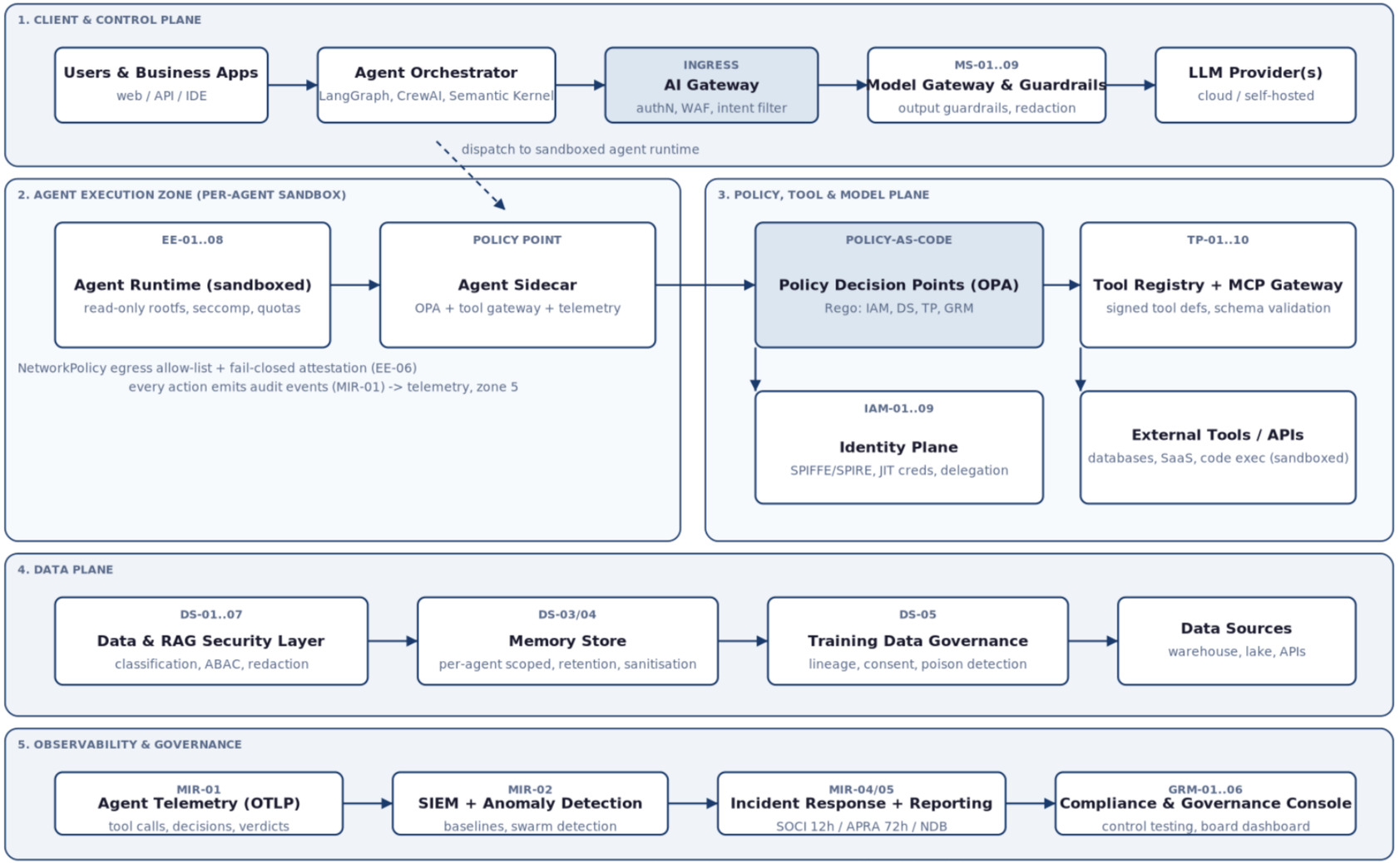
PILLAR 7
Execution Environment

EE-01 .. EE-08 | 8 controls

Isolation enforced, never asserted

From Framework to Deployment

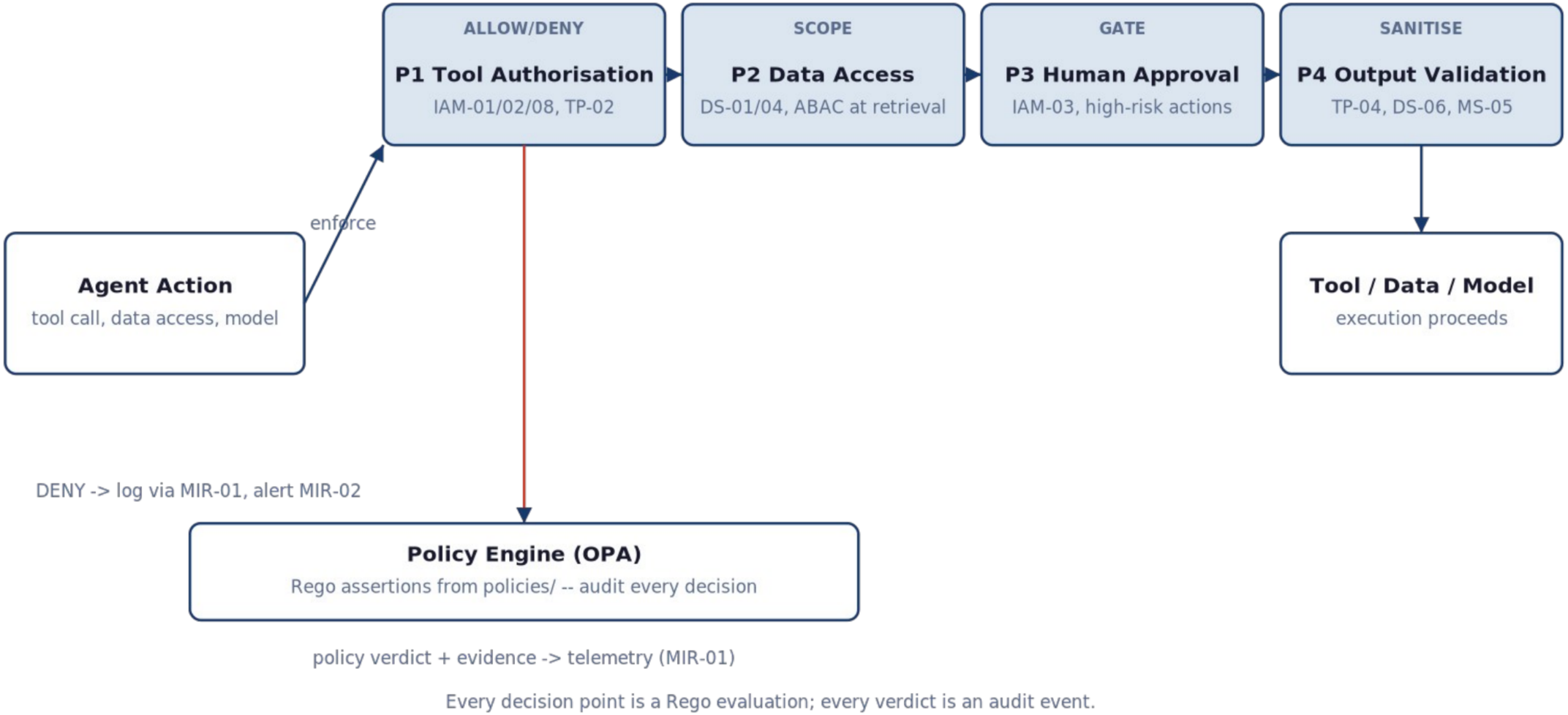
Eight deployable components; every control range mapped



Every component maps to SHIELD-AI controls -- see the component-to-control matrix in this document.

Policy as Code: 59 Controls You Can Run

Deny-override evaluation at every decision point

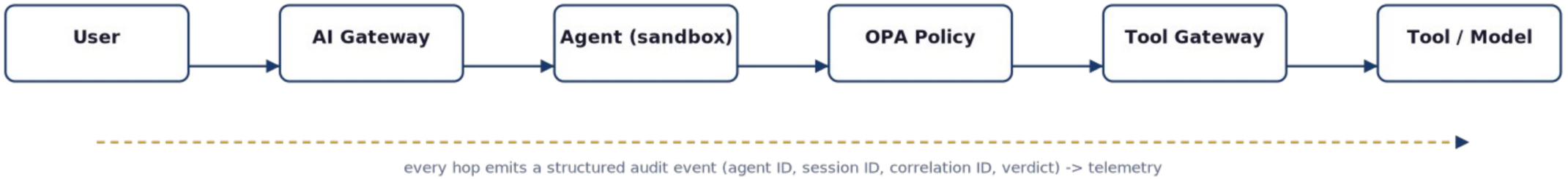


Every decision point is a Rego evaluation; every verdict is an audit event.

Every Request Through the Gate

Parse, evaluate, decide, log, then the agent acts

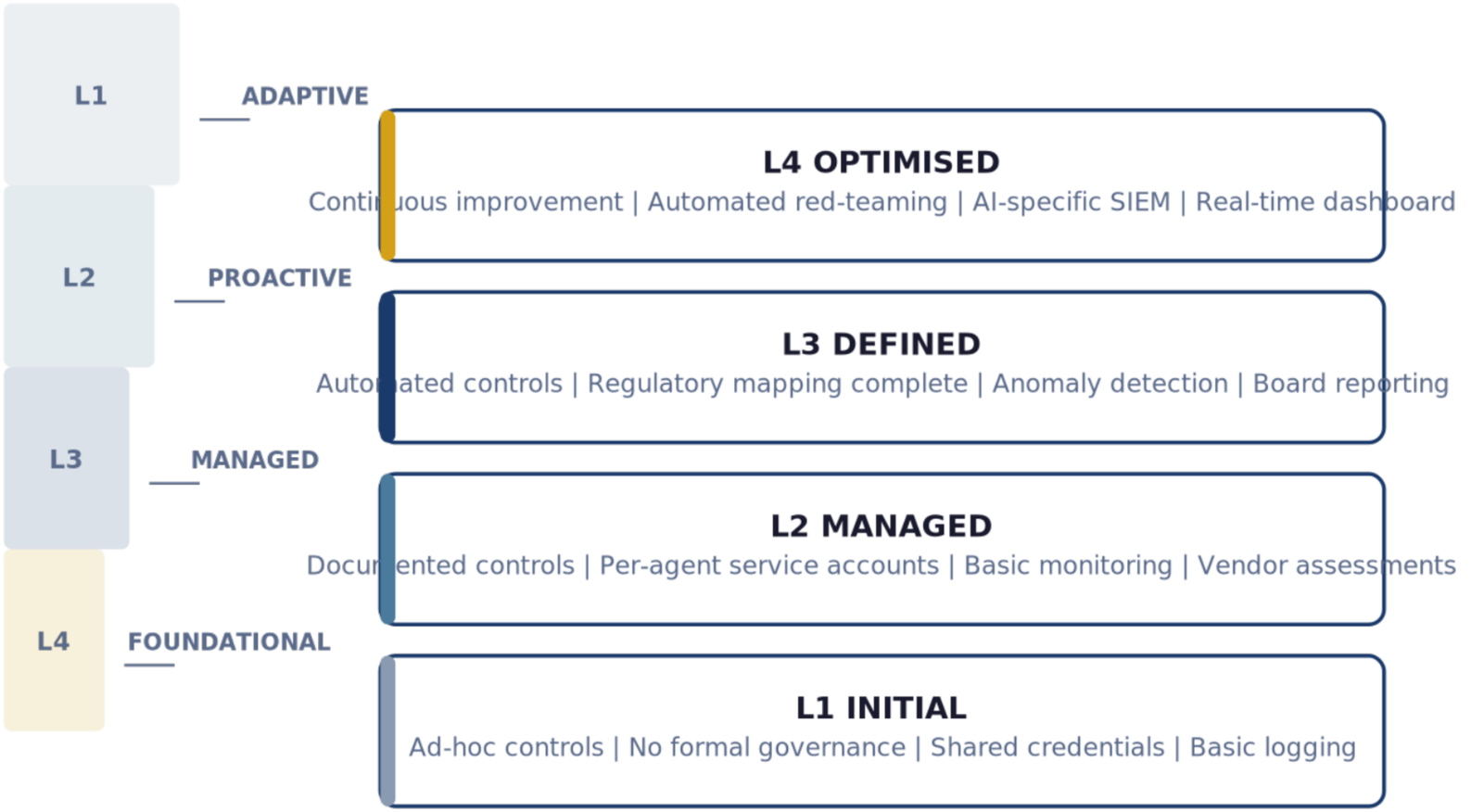
1. User request (authenticated, session-scoped)
2. Gateway: authN, WAF, intent filter, rate limit
3. Agent plans; tool invocation proposed
4. OPA: is agent authorised? scope? approval needed?
5. Tool gateway: schema validation, allow-list, audit
6. Output validated & sanitised before agent context
7. Response returned; full chain logged (MIR-01)



Fail-closed: any unreachable policy/tool/audit dependency blocks the action (EE-06, TP-03).

Maturity: L1 to L4

Consistent with the ISM and Essential Eight maturity model



Typical progression: 3-4 months | 8-12 months | 12+ months

Weakest pillar determines overall maturity

L3 Defined: regulated entities and government agencies. L4 Optimised: critical infrastructure and national security.

Alignment with the Retailer's Regulatory Obligations

Seven pillars against the Privacy Act, PCI DSS, the Cyber Security Act 2024, SOCI, ISM/E8, and the AU Guardrails

SHIELD-AI alignment with a major Australian retailer's obligations

Seven pillars mapped to the regulatory set a national retailer operates under. Solid = direct control mapping. Gold = supporting contribution.

	Privacy Act APP 11 + NDB	PCI DSS Cardholder data	Cyber Security Act 2024 Positive obligations	SOCI Act *Food & grocery	ISM / E8 Security baseline	AU Guardrails High-risk AI
1 Model Security MS-01 .. MS-11	●	●	●	●	●	●
2 Identity & Access IAM-01 .. IAM-09	●	●	●	●	●	●
3 Data Security DS-01 .. DS-07	●	●	●	●	●	●
4 Tool & Pipeline Security TP-01 .. TP-12	●	●	●	●	●	●
5 Monitoring & IR MIR-01 .. MIR-06	●	●	●	●	●	●
6 Governance & Risk GRM-01 .. GRM-06	●	●	●	●	●	●
7 Execution Environment EE-01 .. EE-08	●	●	●	●	●	●

Privacy Act APP 11: customer and loyalty data in prompts, logs, and training sets (DS, MS), with NDB 30-day breach notification (MIR-05, red). PCI DSS: cardholder data flowing through

Solid: direct control mapping. Gold: supporting contribution.

A Practical Starting Point

The framework answers 'where do we start' in five steps

1. Posture assessment: score all seven pillars at L1-L4, find where customer or card data already meets a model
2. Set the floor: make L2 the baseline for the first production system (identity, logging, sandbox, tool registry)
3. Pilot policy as code on one use case: pick the customer service agent or demand forecasting copilot, run it through the gateway, watch the logs
4. Board reporting cadence: GRM-06 dashboard from the first quarter, so the board sees posture, not anecdotes
5. Keep it current: monthly deep review and the live watchlist, so the control set tracks what attackers are actually doing

None of this requires a platform rewrite; the reference implementation drops in beside what the business already runs

Future Threats on the SHIELD-AI Watchlist

Six components under active monitoring; the watchlist is rebuilt monthly by the deep review

Future threat	What is happening	Why it matters to SHIELD-AI
IETF agent-to-agent (A2A) standardisation	Protocol ratification talks may normalise multi-hop agent delegation	Could defeat the two-hop delegation bound (IAM-02/07); delegation-chain amplification
Open Secure AI Alliance / NOOA	NVIDIA and 36 partners, open-sourced guidance (July 2026)	Divergence risk if NOOA guidance contradicts a SHIELD-AI control; a mapping question for GRM-05
Time-based supply-chain defences	TrapDoor (34 packages across npm, PyPI, Crates) showed token-age gates	The fresh-credential problem: agent publishers hold fresh tokens, so age-based gates miss agent-originated publication (DS-07)
Edge and on-device agents	Models like Gemma 4 12B run locally, outside the data centre	MS-09 needs a perception-channel extension (screen, OCR); on-device agents open a MIR-01 telemetry gap
Inbound MCP exposure	OX Security 'by design' flaw (200K servers, 150M downloads); Wiz research; Metasploit 6.5 now ships an MCP server	Strongest promotion candidate: extend TP-10 to standalone MCP servers
Adversary-owned autonomous agents	Unit 42 documented self-scanning campaigns; agent-as-a-service is spreading	Prevention cannot keep pace; rely on detection (MIR-02), automated response (MIR-04), and a tested kill switch (GRM-02)

Each item carries a decision gate: when the gate fires, the item is promoted from watchlist to control.

Queued for the September deep review: inbound MCP exposure (extending TP-10) and A2A standardisation (extending IAM-07).

Why SHIELD-AI for This Business

Aligned: mapped to the Privacy Act, PCI DSS, the Cyber Security Act 2024, SOCI, ISM/E8, and the AU Guardrails the retailer already operates under

Evidence driven: 36 incidents, a monthly deep review, a live watchlist; the controls track what attackers are actually doing

Deployable: a reference implementation with policy as code, ready to run beside existing platforms

Built for regulated customer data: the NDB 30-day clock and PCI DSS scope are design inputs, not afterthoughts

Measurable: the L1-L4 maturity model gives the board a repeatable posture picture, quarter to quarter

Transparent: an open framework with no commercial lock-in, ready for independent evaluation

What This Means in Practice

The question regulators will ask: how is AI secured across the customer data estate, and how do you evidence it?

The answer framework: run the 59 controls as executable policy, and an audit becomes a test run

The path from here:

1. Posture assessment (weeks 1-4): current AI deployments scored L1-L4 against the 59 controls, with a prioritised gap list
2. Pilot (weeks 5-8): policy-as-code enforcement on one real use case, deployed as a sidecar, no platform rebuild
3. Rollout: extend to production workloads, wire to monitoring and audit, keep posture current through the ongoing incident watch

The framework updates weekly against a live incident watch and monthly with a deep review; it does not go stale between engagements

Questions and Discussion

Which customer-facing or supply chain AI capability ships first, and where does customer data meet a model today?

A useful next step: a seven-pillar posture assessment at L1-L4, then a policy-as-code pilot on that first use case.

SHIELD-AI v1.7 | 7 pillars | 59 controls | policy as code | August 2026